CASE STUDY

Five Hacks and Why They Worked: The Cases in Fancy Bear Goes Phishing

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

Plenty of people in our community first met the history of hacking through a book, and the library's Cybersecurity Book List carries one: *Fancy Bear Goes Phishing* by Scott J. Shapiro (Farrar, Straus and Giroux, 2023) [1] [2]. Its publisher copy states its thesis plainly: cybercrime has less to do with defective programming than with the faulty wiring of psyches and society, and hacking is a human-interest story [1] (**Reported**). The book tells that story through five cases: the Morris worm of 1988, the Bulgarian virus writer known as the Dark Avenger, the 2005 break-in to a celebrity's phone, the 2016 intrusions at the Democratic National Committee (DNC), and the Mirai botnet of 2016 [1] [3] (**Reported**).

This study does not retell the book. The book text itself was not opened (a statement about this study's method), so nothing here rests on it except where a claim is labelled as the book's own and graded **Reported**. Instead the study goes to the record behind each chapter: the Second Circuit's opinion in *United States v. Morris* and the 1988 technical analyses from Purdue, MIT and Utah; Vesselin Bontchev's 1991 paper and the *Virus Bulletin* issues of 1990 to 1992; the 2005 Department of Justice release on the juvenile case; the July 2018 indictment of twelve GRU officers, the Special Counsel's report, the DHS and FBI GRIZZLY STEPPE report and the CrowdStrike DNC report; and the USENIX Security 2017 measurement paper on Mirai, the US-CERT alert and the Alaska court filings.

The record mostly bears the book's thesis out, and it adds something the thesis can obscure. In four of the five cases the human failure ran through a technical or procedural default; in Bulgaria it ran through the absence of any law (**Inferred**). Sendmail shipped with debug on, fingerd used `gets()`, and passwords were guessable [11] [12] [13]. Bulgaria had no law against writing viruses and a culture of copying pirated disks [28]. A carrier's store staff handed out credentials over the phone, by the book author's account [38]. Campaign staff typed

passwords into a fake Google page [46] [49]. Hundreds of thousands of cameras and recorders shipped with factory passwords [59] [62]. Twenty-eight years apart, the Morris worm and Mirai both broke in with guessed or default passwords [13] [59].

> Evidence grade: the mechanics of the Morris worm, its timeline, the trial and the sentence are **Confirmed** from court records and the 1988 analyses; the 6,000-machine and multimillion-dollar figures are not, and the library's own row repeats them (Part 6). The Dark Avenger's viruses and their spread are **Confirmed** from Bontchev and *Virus Bulletin*; his identity is not established by any opened source. The 2005 intrusions are **Confirmed** from the DOJ release, which names no victim; the identification of the victim and the method of the phone call are **Reported** from the book's author and the press. The DNC and DCCC intrusions, the personas and the leaks are **Confirmed** from the indictment, the Special Counsel's report and the vendor and government reports. Mirai's growth, mechanics and attacks are **Confirmed** from the USENIX paper and US-CERT, and the guilty pleas from the Alaska filings; the claim that the Mirai authors attacked Dyn is unsupported by any opened source.

Key facts at a glance

Field	Value
The book	Scott J. Shapiro, *Fancy Bear Goes Phishing*, Farrar, Straus and Giroux, on sale 23 May 2023, ISBN 9780374601171 [1] [2]; the book text was not opened
Case 1	The Morris worm, released about 8:30 p.m. on 2 November 1988 from an MIT computer [7] [15]; four entry methods: sendmail debug, fingerd overflow, trusted hosts, password guessing [8]
Case 1 outcome	First person convicted under the 1986 Computer Fraud and Abuse Act, per the FBI [15] (the Cornell Chronicle says first tried [23]); three years probation, 400 hours community service, $10,050 fine [7]; affirmed 7 March 1991 [7]
Case 2	The Dark Avenger, Sofia, Bulgaria; first virus begun September 1988, released March 1989 [29] [30]; the Mutation Engine (MtE) 1992 [33]
Case 2 context	76 of 318 viruses of known origin in one year were Bulgarian, per an industry association [35] (**Reported**)
Case 3	A Massachusetts juvenile; intrusions August 2004 to June 2005 against an ISP, a major telephone provider and an identity-data company; about $1 million in damages; 11 months in a juvenile facility [37]
Case 4	Two Russian services in the DNC: APT29 from summer 2015, APT28 from April 2016 [48] [49]; GRU Unit 26165 phished the Clinton campaign chairman on 19 March 2016 and took over 50,000 emails [46]
Case 4 outcome	Twelve GRU officers indicted in the District of Columbia on 13 July 2018 [46]; over 20,000 DNC emails released on 22 July 2016 [46]
Case 5	Mirai: scanning from 1 August 2016, peak of about 600,000 infections at the end of November 2016 [59]; 623 Gbps against Krebs on Security, 20 September 2016 ET [59] [61]
Case 5 outcome	Informations and plea agreements against three men filed in Alaska on 5 December 2017 [65] [67] [70] [71]; each sentenced on 18 September 2018 to five years probation and $127,000 restitution [74] (**Reported**)
ATT&CK objects	G0007 APT28, G0016 APT29, S0023 CHOPSTICK (X-Agent), S0117 XTunnel, S0002 Mimikatz, S0053 SeaDuke; no object for the Morris worm, the Dark Avenger, the 2005 case or Mirai [50] [51] [53] [54] [75]
Layer	`navigator/library-layers/fancy-bear-goes-phishing.json`

Key findings

- **Most of the cases turned on a default someone could have changed.** Sendmail debug was on by default in 4.3BSD and Sun releases [11]. Mirai needed only 62 factory credentials [59] [62]. The DNC phish needed no exploit at all [46] [49]. (**Confirmed** for each fact; the pattern is **Inferred**.)
- **The 1988 response was run by university staff over mail and phone, and cutting off mail was a mistake.** Academic sites did better than government and commercial ones [18], and MIT's analysts judged that cutting mail cut off the only real defense, information [11] (**Confirmed**). CERT/CC was founded within days at the direction of the Department of Defense [15] (**Confirmed**).

- **The famous Morris numbers are guesses.** The 6,000-machine figure began as an on-camera guess extrapolated from MIT [10]. The Cornell Commission could not confirm it and called a $96 million estimate grossly exaggerated [22] (**Reported**, through the Cornell Chronicle). The court record gives $200 to more than $53,000 per installation [7] (**Confirmed**).
- **The Dark Avenger targeted the defenders.** Two viruses Bontchev attributes to him, V2000 and V2100, claimed authorship by Bontchev; V2100-B was used to trojanize a McAfee scanner, and a fake "universal scanner" uploaded under Bontchev's name infected every file it scanned, though no opened source says who uploaded it [28] [30] (**Confirmed**; the authorship is Bontchev's judgment).
- **The 2005 primary record is thin and the popular story is richer than it.** The DOJ release names no victim and no method of entry to the telephone provider [37]. The book's author says the victim was Paris Hilton and the method a pretext call to a store [38] (**Reported**). Wired's date for that call conflicts with the DOJ window [39].
- **The DNC was two intrusions, not one.** APT29 and APT28 sat in the same network with no collaboration identified [48] [49] (**Confirmed**). The library's DNC entry names only APT28 (Part 6).
- **The GRU ran the leak as an operation.** It built DCLeaks and the Guccifer 2.0 persona, tied them to shared bitcoin-funded infrastructure, and passed about 1 GB to "Organization 1" [46] (**Confirmed** as charged).
- **Nothing on the record ties Mirai's authors to Dyn.** The charged DDoS conduct ends about 4 October 2016 and never mentions Dyn [65]; the USENIX paper attributes Dyn to cluster 6, not the original cluster 1 [59] (**Confirmed**), and Krebs reports it was one of the botnets spawned after the leak [73] (**Reported**). The absence of a link is **Inferred** from the record's silence. The library says otherwise and gives a size that neither the USENIX paper nor US-CERT carries (Part 6).
- **None of these cases has an ATT&CK campaign object**, and only the DNC has group and software objects [51] [52] [54] [75] (**Confirmed**).

What is overstated and what is understated

This is the study's own reading of the record, graded **Inferred** as a judgment; each fact under it carries the grade given where its Part states it.

Overstated.

- **The size of the Morris worm.** The 6,000-machine figure and the multimillion-dollar damage totals travel as fact, but the first began as an on-camera extrapolation and the Cornell Commission could not confirm it or the $96 million estimate [10] [22]. The court found per-site costs, not a total [7] (Part 1.8).
- **Mirai's authors and Dyn.** Popular accounts, and the library's own row, pin the October 2016 Dyn attack on the original authors and give it a size. The measurement paper attributes Dyn to a different cluster, the charged conduct ends on 4 October 2016, and neither the paper nor US-CERT gives a Dyn size [59] [62] [65] (Part 5.3).
- **The election effect.** No opened source measures an effect of the DNC leaks on the 2016 result [3] [46] [47] (Part 4.6).
- **The 2005 phone story.** The named victim, the carrier and the store pretext call rest on the book's author and the press, and the press accounts contradict each other and the DOJ dates [37] [38] [39] [45] (Part 3.2).

- **"First" claims.** Bontchev's record shows the Dark Avenger did not write the first mutating virus, so the book site's "first" holds only for the MtE engine [1] [28] [33], and Mirai was not the first default-credential IoT botnet [59].

Understated.

- **Defaults.** Debug mode on by default, an unsafe library call, world-readable password files and factory passwords did more of the work in 1988 and 2016 than any clever exploit [11] [12] [13] [59] [62] (Part 7.1).
- **The second intruder.** Many retellings of the DNC case name one Russian service; the record shows two in the same network, with no collaboration identified [48] [49] (Part 4.1).
- **The leak as infrastructure.** The personas and leak sites ran on the same bitcoin-funded plumbing as the phishing domains, which is how the indictment ties them to the intrusions [46] (Part 4.5).
- **Attacks on the defenders.** The Dark Avenger trojanized scanners and impersonated a named researcher [28] [30], and the GRU read a security vendor's reporting before it tried to clean up [46].
- **What survived remediation.** A Linux X-Agent stayed on the DNC network for months after the June 2016 eviction [46] (Part 7.3).

Top recommendations

1. **Remove default and guessable credentials at the source.** Change Default Password and Credential Hardening are the library's D3FEND countermeasures for the techniques used in 1988 and in 2016 (Part 7.1).
2. **Use phishing-resistant multi-factor authentication for webmail and identity providers.** The Clinton campaign chairman's account fell to a single credential page [46]; the library maps no D3FEND countermeasure to T1598.003, so this is argued from the record, not from a mapping (Part 7.2).
3. **After you find one intruder, hunt for a second.** Two services shared the DNC for months [48] [49] (Part 7.3).
4. **Forward logs off the host.** The GRU cleared event logs and deleted its own panel logs [46], and CrowdStrike saw both Bears clear logs and reset timestamps [48] (Part 7.4).
5. **Treat support staff, carriers and identity brokers as attack surface.** Recovery and support flows need the rigor of the login itself (Part 7.5).
6. **Test restores against quiet corruption.** The Dark Avenger's virus damaged data slowly enough that backups were already bad [28] (Part 7.6).
7. **Keep channels of information open during an incident.** MIT's analysts judged cutting off mail a mistake, and academic sites, which relied on informal mail and phone, fared better than government and commercial ones [11] [18] (Part 7.7).
8. **Correct the library's 1988, DNC and Mirai rows and the APT28 SolarWinds line** (Part 6).

Scope and method

The study covers the five cases the book is built on [1] [3]. For each it reads the primary record: court opinions, indictments, informations and plea agreements; government releases and advisories; the contemporaneous technical analyses; and the peer-reviewed measurement paper on Mirai. Press and reviews are used where no primary was opened, and are graded down. Every source was opened on 3 November 2026; the date is recorded in the Sources table. Several primaries could not be opened and are named as such where they matter: the book's own text, the Cornell Commission report, the GAO report's scanned PDF, the DOJ releases for the 2018 indictment and the 2017 and 2018 Mirai proceedings, and a tweet by OVH's founder.

> Evidence grades follow the library's case-study method:

Grade	Meaning
Confirmed	A primary source was opened and states the claim
Reported	Only a secondary source (press, a review, the book's own copy, a researcher relaying a third party) was opened
Demonstrated	A public reproduction exists; no case in this study rests on one
Inferred	Reasoning by this study, labelled as such (all retrospective ATT&CK mappings for cases ATT&CK does not cover)

The book is a secondary source. A claim only the book makes is graded **Reported** and attributed to it by title and author. Names of private people are kept to what the record needs: the 2005 juvenile is never named, and the Mirai defendants are named only as the court filings name them. Quotations from any source are kept under 15 words.

Part 1: the Morris worm, November 1988

1.1 Building and launching it

Robert Tappan Morris, a Cornell graduate student, began work on the worm in October 1988 [7] (**Confirmed**). Tests of the sendmail attack show in Cornell mailer logs from 19 to 28 October, per an NCSC analysis of those logs as the MIT team recounts it [10] (**Reported**). He released it on 2 November 1988 from a computer at MIT, chosen to disguise that it came from Cornell [7] (**Confirmed**). The FBI puts the release at around 8:30 p.m. [15] (**Confirmed**). MIT's chronology is more careful: a Cornell log entry at 5:01:59 p.m. that day may have been testing or the launch, and it records the origin time as disputed [10] (**Confirmed**).

1.2 How it got in

The court found four methods: a sendmail bug, a fingerd bug, trusted hosts and password guessing [8] (**Confirmed**).

- **Sendmail debug mode.** In debug mode a connection could name a program as the recipient. The worm's recipient stripped the headers and piped the message body to a shell. The shell wrote and compiled a small "grappling hook", `l1.c`, which pulled down VAX and Sun object files [11] (**Confirmed**). Debug was on by default in 4.3BSD and Sun releases [11] (**Confirmed**). NVD now carries a retroactive record for the

sendmail debug command, CVE-1999-0095, with the weakness listed as NVD-CWE-Other [16] (**Confirmed**).

- **The fingerd overflow.** fingerd read its request with `gets()` into a 512-byte stack buffer. The worm sent 536 bytes, overwriting the saved stack frame so the return jumped to VAX code that ran `/bin/sh` [12] (**Confirmed**). It worked only on VAX 4.3BSD hosts; the same input made Suns dump core [13] (**Confirmed**). No NVD record for the 1988 fingerd bug was found [17] (**Inferred** from absence).
- **Trusted hosts.** Targets came from `/etc/hosts.equiv`, `.rhosts`, `.forward`, netstat routing tables and random addresses. `rsh` relied on host trust, and `rexec` used only passwords the worm had already verified locally [13] (**Confirmed**).
- **Password guessing.** With `/etc/passwd` world-readable, guessing ran in stages: a null password, the account name, the name doubled, first and last names from the GECOS field, the name reversed, a built-in 432-word list, then `/usr/dict/words` [13] (**Confirmed**). Seeley estimated about nine hours for the 432-word list and about four weeks for a full dictionary [12] (**Confirmed**).

1.3 Why it overwhelmed the network

The worm tried not to run twice on a host. A routine called `checkother()` contacted a local listener on TCP port 23357 and rolled dice to decide which copy survived. One copy in seven skipped the check and became immortal, and a losing copy only set a flag and kept working a long time before it exited [13] (**Confirmed**). The court found Morris built the every-seventh rule to defeat administrators who might fake a "yes" reply, and that he underestimated how much copying it would cause [7] (**Confirmed**). The record describes machines crashing or becoming catatonic [7] (**Confirmed**).

1.4 How it hid

It was compiled under the name `sh`, forked about every three minutes, erased its argument list, deleted its binary, disabled core dumps and XOR'd its strings with 0x81 [11] (**Confirmed**). Spafford adds that it kept its files encrypted in memory and used a bootstrap "vector" program to fetch the body [14] (**Confirmed**). Code meant to send a byte to `ernie.berkeley.edu` about once per 15 infections was broken and never sent anything; MIT's packet captures showed no traffic to that host [13] (**Confirmed**).

1.5 The response

Time (2 to 8 Nov 1988)	Event	Source	Grade
2 Nov, 9:00 p.m.	Earliest reported infection, at Stanford; RAND about 9:00 p.m., University of Maryland 10:54 p.m., Berkeley 11:00 p.m.	[10]	**Confirmed**
3 Nov, 2:28 a.m. EST	Peter Yee of NASA Ames posts the first warning to the tcp-ip list (the paper's text says Wednesday; the chronology places it early Thursday)	[10]	**Confirmed**
3 Nov, 3:34 a.m.	Andy Sudduth's anonymous warning from Harvard lists three fixes but sits about 20 hours at relay.cs.net; the court records that it got through too late	[10] [7]	**Confirmed**
3 Nov, 5:58 a.m.	Keith Bostic posts a sendmail fix	[10]	**Confirmed**
3 Nov, 11:30 a.m.	MILNET to ARPANET mailbridges shut down until 11:00 a.m. Friday (DCA, as reported at the NCSC meeting)	[10]	**Reported**
3 Nov, 9:20 p.m.	Spafford creates the phage@purdue.edu mailing list	[10]	**Confirmed**
3 Nov, 10:18 p.m.	Bostic's third posting, a fingerd fix replacing `gets` with `fgets`	[10]	**Confirmed**
8 Nov	NCSC post-mortem in Baltimore with NIST, DCA, DARPA, DOE, BRL, LLNL, the CIA, the FBI and universities; no vendors attended	[10]	**Confirmed**

University staff led the response over informal mail and phone, and academic sites performed better than government and commercial ones [18] (**Confirmed**). MIT and Berkeley decompiled the worm in parallel and agreed not to release decompiled source; MIT's analysts judged that cutting off mail had been a mistake because it cut off information [10] [11] (**Confirmed**).

1.6 What came after

The FBI says the nation's first computer emergency response team was created in Pittsburgh days after the attack, at the direction of the Department of Defense [15] (**Confirmed**). Richard Pethia was CERT's founding director, serving from 1988 to 2016 [20] (**Confirmed**). CERT/CC's first advisory, CA-1988-01 in December 1988, told sites to run sendmail 5.59 with debug disabled [21] (**Confirmed**). The Internet Activities Board issued RFC 1087, "Ethics and the Internet", in January 1989, after an NSF advisory panel statement of 30 November 1988 [19] (**Confirmed**). GAO report IMTEC-89-57 of 12 June 1989 recommended that the Office of Science and Technology Policy coordinate an interagency internet security focal point; GAO lists it as closed, not implemented [24] (**Confirmed** from the product page; the scanned PDF was not read).

The Cornell Commission report was presented to the Provost on 6 February 1989 [18] (**Confirmed**). It concluded Morris was responsible; its public release followed a six-week delay that prosecutors and defense counsel requested [22] (**Reported**; the report itself could not be opened and is cited through the Cornell Chronicle).

1.7 The trial

The Cornell Chronicle described Morris as the first person tried under the 1986 law; the FBI calls him the first person convicted under it [23] [15] (**Confirmed**). Judge Howard G. Munson announced the sentence on 4 May 1990: three years probation, 400 hours of community service, a $10,050 fine and the costs of supervision, in a judgment dated 16 May 1990 [7] (**Confirmed**). The Chronicle gave the fine as $10,000; the court figure governs [7] [23]. The Second Circuit affirmed on 7 March 1991. It held that the intent requirement applies to the access, not to the resulting damage, and that Morris used sendmail and finger without authorization because he used neither for its intended function [7] (**Confirmed**).

1.8 How big was it?

The 6,000-infection figure began as an on-camera guess: 10 percent of MIT's 2,000 hosts, extrapolated to the internet's 60,000 hosts [10] (**Confirmed**). The FBI repeats it and says damage estimates began at $100,000 and ran into the millions [15] (**Confirmed** as the FBI's statement). The Cornell Commission said the 6,000 figure could not be confirmed though the total was surely in the thousands, and called an industry association's estimate of about $96 million grossly exaggerated [22] (**Reported**). The court record gives damage of $200 to more than $53,000 per installation [7] (**Confirmed**). The honest summary: thousands of machines, an unknown total cost, and per-site costs that the court did find.

Part 2: the Dark Avenger and the Bulgarian virus factory, 1988 to 1997

2.1 Where it came from

Bulgarian computer magazines first wrote about viruses in the April 1988 issue of *Komputar za vas*, translated from the German magazine *Chip*. The first viruses seen in Bulgaria were Vienna, then Cascade and Ping Pong, probably imported with pirated software, and local hackers re-assembled Vienna into shorter variants, from 648 down to 348 bytes [28] (**Confirmed**). The Dark Avenger told the researcher Sarah Gordon that an article in the May 1988 issue set him off and that he began his first virus in September 1988 [29] (**Confirmed** as his statement; the month of the article conflicts with Bontchev's April). *Virus Bulletin*'s December 1990 eyewitness report from Bulgaria gives a September 1988 start and a March 1989 release [30] (**Confirmed**).

Vesselin Bontchev, who studied the Dark Avenger's work from Sofia, explained the "virus factory" in 1991. Bulgaria had many qualified programmers who were underpaid or unemployed, paid 100 to 120 times less than their US peers. Piracy was common. There was no software copyright law and no law against creating or spreading viruses or against illegal access. Anti-virus work was weakly organised, the public treated it as a joke, and technical information was easy to get. No measures could be taken against the Dark Avenger in Bulgaria [28] (**Confirmed** as Bontchev's analysis). Wired later reported that Pravetz 82 clones went into Bulgarian schools from 1982 and that Bulgaria at its peak supplied 40 percent of Eastern bloc computers [36] (**Reported**). An industry association counted 76 of 318 viruses of known origin in one year as Bulgarian, and Bontchev tied that to state-driven hardware cloning [35] (**Reported**).

2.2 The Dark Avenger virus

The virus appeared in spring 1989 carrying a "Sofia 1988-89 Dark Avenger" copyright string. It was a fast infector, so a scan by an anti-virus program that did not know it infected every executable it touched. Reports came from Europe, the USA, the USSR, Thailand and Mongolia [28] (**Confirmed**). On every 16th run it overwrote a random disk sector with the first 512 bytes of the virus, leaving the string "Eddie lives...somewhere in time!" in damaged files. The damage was slow and silent, so backups were often already corrupt when anyone noticed [28] (**Confirmed**).

Virus Bulletin's February 1990 dissection describes a parasitic resident virus that infected .COM and .EXE files of 1,775 bytes or more, with an infective length of 1,800 bytes. It allocated a 3,680-byte block at the top of memory marked as owned by the operating system, hooked INT 21H and INT 27H, and kept a run counter in the boot sector. It had been reported in Bulgaria, eastern Europe, West Germany and Moscow, with none confirmed in the UK at that date [31] (**Confirmed**). The magazine took "Eddie" to be Iron Maiden's mascot; the Dark Avenger later told Gordon the phrase came from an old song, not Iron Maiden [31] [29] (**Reported**; each side is attributed).

2.3 Attacking the defenders

Bontchev attributes to the same author the Dark Avenger, V2000, V2100, 651, Diamond, Nomenklatura, 512, 800, 1226, Proud, Evil, Phoenix, Anthrax and Leech [28] (**Confirmed** as Bontchev's judgment). V2000 and V2100 claim authorship by "Vesselin Bontchev" and hang the machine when a program containing that string runs. V2100-B was used to trojanize version 66 of McAfee's VirusScan [28] (**Confirmed**). *Virus Bulletin* independently reported a copy of McAfee's ViruScan containing a virus with its self-check modified, and a trojanized AFD debugger; Alan Solomon reported source code for the Dark Avenger, Yankee Doodle and V1024 uploaded to his company's bulletin board [30] (**Confirmed**).

A file called UScan, uploaded by a user logged in as "Vesselin Bontchev" and posing as his universal virus scanner, infected every scanned file with Anthrax. Infected files reached bulletin boards in the UK, Sweden (*Virus Bulletin* says Norway), the Netherlands and Greece [28] (**Confirmed**). Asked why his viruses destroy data, the Dark Avenger replied that "destroying data is a pleasure", as Bontchev printed it [28] (**Confirmed**).

In the 1992 interview the Dark Avenger expressed regret for the first virus's destructive code, blamed piracy for its spread, called Bontchev "the weasel" and said that naming him had made the Dark Avenger. Gordon states that the Dark Avenger is not Bontchev [29] (**Confirmed** as published). No opened source establishes the Dark Avenger's identity.

2.4 The Virus eXchange and mutation

The Virus eXchange bulletin board in Sofia, run from home by a computer science student, required users to upload a new virus to reach its virus area. It held about 300 viruses with source freely available, and the Dark Avenger and a writer known as W.T. were its most active users [28] (**Confirmed**). Wired says it ran from 1990 to 1993 on one line with a 2400-baud modem, that its operator vanished in 1993, and it airs and records a denial of a rumour that he and the Dark Avenger were one person [36] (**Reported**).

Leech can exist in more than 4.5 billion variants, but 1260 was the first fully mutating virus [28] (**Confirmed**). A message signed by the Dark Avenger, uploaded to Bulgarian boards in March 1991 and later to FidoNet, announced a virus that would mutate in about 4 billion ways [32] (**Confirmed**). The Mutation Engine, MtE 0.91, shipped as `MTE.OBJ` with documentation, a demonstration virus called Dedicated in source and object form,

and a random number generator, with support offered through a Bulgarian virus exchange board. Any virus could call it through one subroutine. Dedicated, Fear and Pogue used it, and Pogue was reported in the wild in the US [33] (**Confirmed**). The demonstration virus carried a dedication to Sarah Gordon [29] (**Confirmed**).

The book's site says the Dark Avenger invented the first mutating virus engine [1] (**Reported**). That fits the record only if it means MtE: Bontchev's 1991 paper shows Leech was not the first mutating virus [28], so the claim holds for the engine, not for mutation itself (**Inferred**). Two years after MtE appeared only a handful of scanners detected it, Bontchev wrote, citing his 1993 test; about 1992 the Dark Avenger wrote Commander_Bomber, which scatters code fragments through COM files to defeat scanners that look at the entry point or the top and tail of a file [34] (**Confirmed**); Wired dates it 1993 [36] (**Reported**).

2.5 How far it spread

Of more than 160 Bulgarian viruses only a few spread widely in the West. John McAfee estimated that about 10 percent of US infections were Bulgarian [28] (**Reported**; the McAfee figure and a German DM 10 million damage figure for Vacsina are relayed by Bontchev, not verified). Bontchev founded the national virology lab at the Bulgarian Academy of Sciences in 1990 and left for Hamburg in 1991 [36] (**Reported**); he was at the Virus Test Center at the University of Hamburg by 1994 [34] (**Confirmed**). In January 1997 someone calling himself the Dark Avenger held Sofia University systems for two days using DNS spoofing and also entered BIS OnLine; no one could say it was the original author [36] (**Reported**).

Part 3: the phone case, 2004 to 2005

3.1 The record

The primary record is one Department of Justice release from the District of Massachusetts, dated 8 September 2005 [37]. A Massachusetts juvenile pled guilty before Judge Rya W. Zobel to a nine-count juvenile delinquency information. The adult equivalents of the counts were bomb threats, damage to a protected computer, wire fraud, aggravated identity theft and obtaining information from a protected computer, plus a count transferred from the Eastern District of Arkansas. He was sentenced to 11 months in a juvenile facility and two years of supervised release barred from computers, cell phones and other internet devices. Victims' damages were about $1 million, and the Secret Service and FBI investigated [37] (**Confirmed**). The release names no victim or company.

Date	Event in the DOJ release	Source	Grade
March 2004 and spring 2005	Bomb threats to schools	[37]	**Confirmed**
August 2004	Entry to a major ISP through a program installed on an employee's computer for remote use	[37]	**Confirmed**
January 2005	Access to a major telephone provider's internal system to look up customer accounts, access data stored on one customer's mobile phone and post it online, and create free accounts	[37]	**Confirmed**
January 2005	An associate sets up accounts at a company holding identity data on millions	[37]	**Confirmed**
June 2005	A threat to a second provider, followed about ten minutes later by a denial of service against its web operations	[37]	**Confirmed**

Date	Event in the DOJ release	Source	Grade
8 September 2005	Guilty plea and sentence	[37]	**Confirmed**

3.2 The popular story

The book's author has said in an interview that the victim was Paris Hilton, the provider T-Mobile and the device a Sidekick 2. He says the hacker was a 16-year-old he interviewed, who phoned a T-Mobile store posing as corporate staff and was given a username and password, then had a browser pose as a Sidekick to reach her account; the FBI had raided the boy's home when he was 15 [38] (**Reported**). The book's site describes him as a sixteen-year-old from South Boston [1] (**Reported**). This study does not name him.

The press record disagrees with itself. Wired dates the pretext call to a store near Los Angeles on 19 February 2004 and says her address book, messages and photos leaked [39] (**Reported**); that date sits outside the DOJ's January 2005 window for the provider intrusion, and Wired also conflates his 2014 sentence with this case. UPI places the hack in 2008 with 18 counts, contradicting the DOJ's 2005 record of nine counts [45]; this study does not rely on UPI for any fact. The hacker was reportedly one of several, and a group calling itself the Defonic Team Screen Name Club claimed the Sidekick hack [40] (**Reported**). CNBC, citing the Washington Post, describes a group of five aged 19 to 24 that also hacked LexisNexis, plus the minor [41] (**Reported**); LexisNexis is named as the identity-data company only in secondary sources.

3.3 Afterwards

In June 2014 the same person, now an adult, was charged in Massachusetts with two counts of computer fraud and one of access device fraud. The charges covered a community college instructor's credentials used about 24 times with grades changed seven times, a police chief's email, law-enforcement servers from August to November 2012, and payment card data for more than 14,000 account holders from May 2011 to May 2013 [42] (**Reported**). On 27 October 2014 Senior Judge Mark L. Wolf sentenced him to four years plus three years of supervised release with no computer use; the Boston Globe notes earlier state prison time for card fraud and the federal juvenile term for the phone hack [43] (**Reported**). He apologised to Paris Hilton in a TODAY segment [44] (**Reported**). A related 2014 California case alleged that a Zendesk flaw between 16 and 19 February 2013 exposed Twitter support tickets used to take over corporate Twitter accounts [40] (**Reported**).

Part 4: the DNC and the Clinton campaign, 2015 to 2017

4.1 Who was there

CrowdStrike found two separate Russian-linked groups in the DNC: COZY BEAR (APT29) from summer 2015 and FANCY BEAR (APT28) from April 2016, with no collaboration identified between them [48] (**Confirmed**). The DHS and FBI GRIZZLY STEPPE report confirms two Russian intelligence actors in a US political party, APT29 from summer 2015 and APT28 from spring 2016 [49] (**Confirmed**). ATT&CK attributes G0007 APT28 to GRU 85th GTsSS military unit 26165 and G0016 APT29 to the SVR, and says APT29 reportedly compromised the DNC from summer 2015 [50] [54] (**Confirmed** as ATT&CK's wording). No G0016 procedure row names the DNC [54].

The July 2018 indictment, received in the District of Columbia on 13 July 2018 as case 1:18-cr-00215-ABJ, charges twelve GRU officers [46] (**Confirmed**). It says the GRU had multiple units, including 26165 and 74455, running cyber operations with staged releases of stolen documents [46] (**Confirmed**). Netyksho

commanded Unit 26165, which had primary responsibility for hacking the DCCC, the DNC and Clinton campaign accounts [46] (**Confirmed**). Unit 74455, at 22 Kirova Street in Khimki and known as the Tower, helped release and promote the stolen documents through DCLeaks and Guccifer 2.0 [46] (**Confirmed**). This study is the home for the 2016 DNC and DCCC detail. The wider record of Unit 26165 and of APT29 is in the Russia-attributed threat actors study, and Unit 74455's operations, which researchers call Sandworm, are in the Sandworm study. Count One charges conspiracy under 18 U.S.C. 371 and 1030, Counts Two to Nine aggravated identity theft, Count Ten conspiracy to launder money, and Count Eleven a conspiracy by two Unit 74455 officers over election-administration intrusions [46] (**Confirmed**).

4.2 APT29, summer 2015

In summer 2015 an APT29 spearphishing campaign sent a malicious link to over 1,000 recipients, including US government victims, using legitimate domains, and compromised a US political party [49] (**Confirmed**). APT29 established persistence, escalated privileges, enumerated Active Directory accounts and exfiltrated email over encrypted connections [49] (**Confirmed**). In the DNC, COZY BEAR used the SeaDaddy implant (Python built with py2exe, running as `pagemgr.exe`), a PowerShell backdoor persisted through WMI that ran modules in memory, PowerShell Mimikatz and encrypted HTTP command and control, along with RATs called AdobeARM, ATI-Agent and MiniDionis [48] (**Confirmed**). ATT&CK S0053 SeaDuke carries SeaDaddy as an alias [51] (**Confirmed**).

4.3 APT28 and the GRU, spring to autumn 2016

Date	Event	Source	Grade
10 to 15 Mar 2016	Unit 26165 sends about 90 spearphishing emails to hillaryclinton.com accounts; from 15 March it targets campaign staff Google accounts and some dnc.org accounts	[47]	**Confirmed**
Mar 2016	Reconnaissance of democrats.org, hillaryclinton.com, dnc.org and dccc.org begins before the GRU holds credentials: targeted, not opportunistic	[47]	**Confirmed**
15 Mar 2016	Yermakov runs technical queries on DNC IP configurations to identify connected devices and searches open-source information about the DNC (DCCC queries follow on 7 April)	[46]	**Confirmed**
19 Mar 2016	Lukashev sends the campaign chairman a spearphish spoofed as a Google security notification, its link masked through a URL-shortening account (john356gh), to a GRU-created site; the instructions are followed	[46]	**Confirmed**
19 Mar to 6 Apr 2016	Further spoofed phishing of campaign staff from hi.mymail@yandex.com; on 6 April an account mimicking a known campaign member's address phishes employees	[46]	**Confirmed**
21 Mar 2016	Over 50,000 emails stolen from the chairman's account	[46]	**Confirmed**
12 Apr 2016	Entry to the DCCC with credentials of an employee phished around 6 April; X-Agent installed on at least ten DCCC computers	[46]	**Confirmed**
Apr 2016	X-Agent reports to the "AMS panel" on a GRU-leased server in Arizona; operators use keylogging and screenshots to watch DCCC employees	[46]	**Confirmed**
15 Apr 2016	A DCCC computer is searched for "hillary", "cruz" and "trump"; folders such as "Benghazi Investigations" copied	[46]	**Confirmed**
18 Apr 2016	Entry to the DNC from the DCCC network using credentials keylogged from a DCCC employee with DNC access; about 33 DNC computers reached by June	[46]	**Confirmed**
19 Apr 2016	dcleaks.com registered through an anonymizing service after an attempt on electionleaks.com, paid from a cryptocurrency account that also funded a VPS	[46]	**Confirmed**
From 20 Apr 2016	An overseas "middle server" proxies between X-Agent and the AMS panel	[46]	**Confirmed**
22 and 28 Apr 2016	Gigabytes of DNC data compressed with a public tool and moved by X-Tunnel over encrypted channels to a GRU-leased computer in Illinois	[46]	**Confirmed**
30 Apr to 1 May 2016	CrowdStrike contacted, then begins investigating	[48]	**Confirmed**
13 May 2016	Event logs cleared on a DNC computer	[46]	**Confirmed**
25 May to 1 Jun 2016	The DNC Microsoft Exchange server hacked and thousands of work emails stolen; Yermakov researches PowerShell commands for Exchange	[46]	**Confirmed**
31 May to 1 Jun 2016	After researching a security company's reporting on X-Agent and X-Tunnel, the GRU tries to delete traces on the DCCC network with CCleaner	[46]	**Confirmed**

Date	Event	Source	Grade
8 Jun 2016	dcleaks.com launches, claiming to be "American hacktivists", with a Facebook page under the fictitious "Alice Donovan" and the Twitter account @dcleaks_; it later draws over one million page views	[46]	**Confirmed**
10 to 13 Jun 2016	CrowdStrike remediation	[48]	**Confirmed**
14 Jun 2016	The DNC announces the Russian intrusion; CrowdStrike publishes its report. The GRU registers actblues.com and uses stolen DCCC credentials to redirect DCCC website visitors there	[46] [48]	**Confirmed**
15 Jun 2016	Guccifer 2.0 created as a supposed lone Romanian hacker; phrases searched on a Unit 74455 Moscow server, then the first post at 7:02 p.m. Moscow time	[46]	**Confirmed**
20 Jun 2016	AMS panel logs, including login history, deleted	[46]	**Confirmed**
Jun 2016	Illinois State Board of Elections compromised through a website vulnerability; SQL injection against voter databases	[47]	**Confirmed**
Jun to Jul 2016	Unit 74455 researches election sites for vulnerabilities and steals data on about 500,000 voters from a state board of elections website	[46]	**Confirmed**
6 Jul 2016	A VPN bought from a shared bitcoin pool, which also leased the Malaysian server hosting dcleaks.com, is used to log into @Guccifer_2	[46]	**Confirmed**
14 to 18 Jul 2016	An encrypted access file sent to "Organization 1", which confirms receipt of a roughly 1 GB archive	[46]	**Confirmed**
22 Jul 2016	Organization 1 releases over 20,000 DNC emails and documents, about three days before the Democratic National Convention	[46]	**Confirmed**
27 Jul 2016	First GRU attempt on a domain used by Clinton's personal office (15 accounts, within about five hours of a public remark by candidate Trump); 76 campaign addresses targeted	[46] [47]	**Confirmed**
Aug 2016	A voter-registration software vendor hacked	[46]	**Confirmed**
15 and 22 Aug 2016	As Guccifer 2.0, documents about an opponent sent to a congressional candidate, and about 2.5 GB of DCCC data with records of more than 2,000 donors sent to a state lobbyist	[46]	**Confirmed**
From 20 Sep 2016	DNC systems on a third-party cloud service accessed; snapshots made with the provider's own feature and moved to GRU accounts on the same service; about 300 GB stolen	[46] [47]	**Confirmed**
7 Oct to 7 Nov 2016	Organization 1 releases the chairman's emails in about 33 tranches	[46]	**Confirmed**
To about Oct 2016	A Linux X-Agent talking to GRU-registered linuxkrnl.net remains on the DNC network despite remediation	[46]	**Confirmed**
Nov 2016	Over 100 spearphishing emails (the Special Counsel says over 120 accounts) with malware-laden Word documents bearing the vendor's logo sent to Florida county election officials	[46] [47]	**Confirmed**

Date	Event	Source	Grade
29 Dec 2016	GRIZZLY STEPPE published; the US government assesses that APT28's stolen information was leaked to the press	[49]	**Confirmed**
12 Jan 2017	A Guccifer 2.0 post falsely claims no relation to the Russian government	[46]	**Confirmed**
About Mar 2017	dcleaks.com shuts down	[46]	**Confirmed**
13 Jul 2018	Indictment received	[46]	**Confirmed**

The Special Counsel summarises the result: more than 30 DNC computers between 18 April and 8 June 2016, including the mail and shared file servers, using X-Agent, X-Tunnel, Mimikatz and `rar.exe` [47] (**Confirmed**). GRIZZLY STEPPE adds that APT28 relied heavily on shortened URLs and lookalike domains, and that the spring 2016 phishing tricked recipients into "changing" passwords on a fake webmail domain [49] (**Confirmed**).

4.4 The tools

FANCY BEAR used X-Agent (`twain_64.dll`, run through `rundll32`, with command execution, file transfer and keylogging) and X-Tunnel (`VmUpgradeHelper.exe`, for tunnelling), deployed with RemCOM, an open-source alternative to PsExec [48] (**Confirmed**). Both groups periodically cleared the System and Security event logs with the built-in `wevtutil` utility and reset file timestamps [48] (**Confirmed**). ATT&CK S0023 CHOPSTICK carries X-Agent as an alias and cites the CrowdStrike DNC report, and the S0117 XTunnel description names the DNC [55] [56] (**Confirmed**). S0002 Mimikatz has a library page [57] (**Confirmed**). RemCOM and CCleaner have no ATT&CK software objects [52] (**Confirmed**).

4.5 Money and infrastructure

The defendants conspired to launder the equivalent of more than $95,000, mainly in bitcoin, part of it mined by the GRU, through hundreds of email accounts and fictitious names. The same mining pool funded the phishing domains accounts-qooqle.com and account-goooogle.com [46] (**Confirmed** as charged). The operational email behind the cryptocurrency account that paid for dcleaks.com also registered the john356gh URL-shortener account used against the chairman [46] (**Confirmed**). That shared plumbing is how the indictment ties the "hacktivist" sites to the intrusions.

4.6 What the record does not say

The book leaves open whether the hack changed the 2016 result, by one reviewer's account [3] (**Reported**). No source opened for this study measures an effect on the election. The library's DNC entry asserts a "measurable effect"; that is unsupported here (Part 6).

Part 5: Mirai and the botnet wars, 2016 to 2018

5.1 How it spread

Mirai began scanning on 1 August 2016 from a single IP address in a bulletproof hosting center, and infections spread with a 76-minute doubling time [59] (**Confirmed**). Reports appeared as early as 31 August [59] (**Confirmed**). It held a steady 200,000 to 300,000 infections in September, peaked at about 600,000 at the end of November and fell to roughly 100,000 by late February 2017 [59] (**Confirmed**).

The mechanics were simple. Bots sent stateless SYN probes to pseudorandom IPv4 addresses on Telnet ports 23 and 2323, skipping a hard-coded blacklist, then tried 10 username and password pairs drawn from 62 credentials. Results went to a report server, and a separate loader fingerprinted the device and dropped a binary built for its architecture [59] (**Confirmed**). After infection the bot deleted its binary, renamed its process to a random string, did not persist across a reboot, and killed processes on TCP ports 22 and 23 along with rival malware such as other Mirai, .anime and Qbot [59] (**Confirmed**). US-CERT also cites the 62 default credentials and advises watching 2323/TCP and 23/TCP, rebooting and changing default passwords [62] (**Confirmed**).

Mirai evolved from BASHLITE, which used 6 usernames and 14 passwords, and the paper names Carna, with 420,000 bots, as the first IoT botnet built from default credentials [59] (**Confirmed**). Infected devices were mainly IP cameras, DVRs and consumer routers; the paper traces the 46 unique passwords in the 30 September release to vendors including Dahua, HiSilicon, ZTE, Ubiquiti, Xerox and Panasonic [59] (**Confirmed**). Across 24 binaries from 7 August to 30 September 2016, command and control moved from IP addresses to domains in mid-September, self-deletion and process-name obfuscation arrived at the same time, and rival-killing appears in a 29 September sample [59] (**Confirmed**). The paper's table of command-and-control attack commands lists ten flood types, HTTP, UDP-PLAIN, UDP, ACK, SYN, GRE-IP, ACK-STOMP, VSE, DNS and GRE-ETH, with HTTP floods the most common at 2,736 attacks [59] (**Confirmed**).

5.2 The attacks

Date	Event	Source	Grade
1 Aug 2016	Scanning begins from one bulletproof-hosted IP	[59]	**Confirmed**
Aug 2016	Jha demands payment from a US company to stop an attack; a feud with rival botnet operators brings fraudulent abuse complaints, DDoS and a BGP hijacking scheme	[65]	**Confirmed**
Sep 2016	White moves the Mirai command server to BackConnect and uses a compromised computer in France as a proxy	[66]	**Confirmed**
20 Sep 2016, about 8 p.m. ET	Attack on Krebs on Security, first put at about 665 Gbps, then closer to 620; Akamai's previous largest was 363 Gbps; no amplification or reflection	[61]	**Confirmed** (Akamai figures relayed by Krebs)
21 Sep 2016 UTC	The paper measures the Krebs attack at 623 Gbps; 96.4% of Akamai's 12,847 attack IPs overlapped Mirai scanners	[59]	**Confirmed**
25 Sep 2016	An HTTP flood on Google Shield; 96% of its 158,839 IPs overlapped Mirai scanners	[59]	**Confirmed**
Late Sep 2016	A separate Mirai attack on OVH of at least 1.1 Tbps and possibly 1.5 Tbps	[62]	**Confirmed**
30 Sep 2016	Source released on Hackforums; the variant ecosystem explodes	[59]	**Confirmed**
4 Oct 2016	End of the charged Mirai DDoS conspiracies	[65] [66]	**Confirmed**
14 Oct 2016	US-CERT TA16-288A published	[62]	**Confirmed**
21 Oct 2016	Dyn: 23 attack commands from 11:07 to 16:55 UTC, short SYN floods on DNS port 53 then sustained one- and five-hour attacks, and a final ten-hour attack at 22:17 UTC on Dyn and PlayStation infrastructure; disrupted clients included Amazon, GitHub, Netflix, PayPal, Reddit and Twitter	[59]	**Confirmed**
31 Oct to 13 Dec 2016	Cluster 2 issues 341 attacks on Lonestar Cell in Liberia	[59]	**Confirmed**
From 26 Nov 2016	A TCP/7547 CWMP variant scans, alongside the Deutsche Telekom outage	[59]	**Confirmed**
Dec 2016 to Feb 2017	The clickfraud botnet: over 100,000 devices including ISP home routers, about 200 bitcoin, worth over $180,000 on 29 January 2017	[69]	**Confirmed**
18 Jan 2017	Krebs names Jha and White as likely co-authors after a four-month inquiry	[63]	**Confirmed**
5 Dec 2017	Four informations and the plea agreements filed in the District of Alaska	[65] [66] [67] [68] [69] [70] [71] [72]	**Confirmed**

Date	Event	Source	Grade
12 Dec 2017	Pleas unsealed	[73]	**Reported**
18 Sep 2018	Sentencing in Alaska	[74]	**Reported**

From 27 September 2016 to 28 February 2017 the paper counted 15,194 attacks on 5,046 victims from 484 command-and-control IPs: 32.8% volumetric, 39.8% TCP state exhaustion, 34.5% application-layer and 2.8% amplification. Targets included game servers, telecoms, anti-DDoS providers and political sites [59] (**Confirmed**). The paper names cluster 1, with 58,335 bots, as the original botnet behind the Krebs and OVH attacks, and OVH was the top victim network with 7.8% of attacks [59] (**Confirmed**). OVH's founder tweeted that the target was a Minecraft server [63] (**Reported**; the tweet was not opened).

5.3 Nothing on the record ties Dyn to the authors

71% of Dyn's 107,464 attacking IPs overlapped Mirai scanners. The paper attributes the Dyn attack to cluster 6, with 61,440 bots, and judges the target was likely gaming infrastructure, PlayStation name servers, with Dyn's customers hit incidentally [59] (**Confirmed** as the paper's finding; the gaming motive is the paper's own inference). Krebs reports that Dyn was hit by one of the botnets spawned after the source leak [73] (**Reported**). No opened source ties the Dyn attack to Jha, White or Norman: the charged DDoS conduct ends about 4 October 2016 and never mentions Dyn, and neither the USENIX paper nor US-CERT gives a size for the Dyn attack [59] [62] [65] (**Inferred** from the record's silence).

5.4 The cases in Alaska

Four informations were filed on 5 December 2017 in the District of Alaska: 3:17-cr-00163 (Jha, clickfraud), 00164 (Jha, Mirai DDoS), 00165 (White, Mirai DDoS) and 00166 (Norman, clickfraud). Each charges one count of conspiracy under 18 U.S.C. 371 to violate 18 U.S.C. 1030(a)(5)(A) [65] (**Confirmed**).

- **Jha (Mirai).** The conspiracy ran from about July 2016 to 4 October 2016. He wrote the command-and-control code with co-conspirators, and over 300,000 devices joined, some in Alaska. He used the monikers "ogmemes" and "Anna Senpai" [65] (**Confirmed**). He ran Mirai on virtual machines at his family's home with command servers at hosting providers, and Mirai's attacks on whole address ranges damaged nearby servers [65] (**Confirmed**). He posted the Mirai code online for plausible deniability and securely erased the VM that ran it; the information and plea date this "September and October 2017", which conflicts with the 2016 release and is likely a typo [65] (**Confirmed** as written; the typo reading is **Inferred**). The poster "Anna-senpai" claimed a maximum of 380,000 Telnet bots, down to about 300,000 after the Krebs attack [64] (**Reported**). His plea agreement admits the overt acts; the statutory maximum is five years, $250,000 or twice the gain or loss, three years of supervised release and a $100 assessment [67] (**Confirmed**).
- **White (Mirai).** His conspiracy ran from about August 2016 to 4 October 2016; he scanned for IoT devices, including in Alaska [66] (**Confirmed**). His plea agreement is a scanned copy whose text was only partly extracted [68] (**Confirmed** that it exists).
- **Norman (clickfraud).** He earned over 30 bitcoin, worth over $60,000 on 29 January 2017, found vulnerable devices and wrote infection code [71] (**Confirmed**). Krebs gives about $27,000, attributing it to prosecutors [73]; the information's 'over $60,000' governs [71]. His plea agreement is a scanned copy [72]

(**Confirmed** that it exists). Jha's clickfraud plea is document 5 in 3:17-cr-00163 [70] (**Confirmed**).

Krebs reports that Jha and White co-founded Protraf Solutions LLC, a DDoS-mitigation firm, and that Jha agreed to forfeit 13 bitcoin in the clickfraud case [73] (**Reported**). At sentencing on 18 September 2018 each defendant got five years probation, 2,500 hours of community service and $127,000 in restitution, the court citing extraordinary cooperation. The case sat in Alaska because the FBI agent who led it found infected DVRs there, and Jha had admitted to a friend that a customer renting Mirai paid for the Krebs attack [74] (**Reported**; the DOJ release and judgments were not opened). Jha also pleaded guilty in New Jersey to DDoS attacks on Rutgers, where he studied computer science [73] (**Reported**; the New Jersey sentence was not checked). Daniel Kaye ("Bestbuy") was found guilty in Germany for the Deutsche Telekom attacks and received a suspended sentence [73] (**Reported**).

Part 6: corrections for the library

These are the library defects this study found. Each is graded; none is fixed by this study.

Library page	What it says	What the record says	Grade
NOTABLE_INCIDENTS.md, 1988 row	About 6,000 Unix machines "crashed", about 10% of the internet; $100K to $10M damage	The 6,000 figure is an extrapolated guess the Cornell Commission could not confirm [10] [22]; the court says machines crashed or went catatonic [7]; no opened primary supports a $10M upper bound; the court gives $200 to more than $53,000 per installation [7]	**Inferred** [25]
NOTABLE_INCIDENTS.md, 2016 DNC entry	Names APT28 only; "measurable effect on 2016 US presidential election"	Two actors, APT29 and APT28 [48] [49]; no opened source measures an electoral effect [3]	**Inferred** [25]
NOTABLE_INCIDENTS.md, 2016 Mirai entry	"First IoT botnet"; Dyn attributed to the Mirai authors; "1.2+ Tbps" against Dyn	The USENIX paper names Carna as the first default-credential IoT botnet [59]; Dyn is attributed to a post-leak cluster [59] [73]; no Dyn size in the USENIX paper or US-CERT [59] [62]	**Confirmed** (paper) and **Inferred** (absence)
THREAT_ACTORS.md, APT28 entry	Lists "SolarWinds (suspected)"	ATT&CK puts C0024 SolarWinds Compromise under G0016 APT29 [54]; the SolarWinds and SUNBURST study has the record	**Inferred**

Part 7: the defender view

7.1 Default and guessable credentials, 1988 to 2016

The worm guessed account names and a 432-word list [13]; Mirai tried 10 of 62 factory pairs [59]. Both gained footholds through guessed or default passwords, the worm alongside two exploits (**Inferred**). The library maps Change Default Password, Account Locking, Strong Password Policy, Credential Hardening and Multi-factor Authentication to the password techniques both used [57] [27] (**Confirmed** as library mappings). The book's policy lesson points the same way: Kirkus describes its case for building security in, citing California's connected-device "reasonable security" law [5] (**Reported**). Practical steps: unique per-device credentials at manufacture, no Telnet on internet-facing devices, and watching 23/TCP and 2323/TCP as US-CERT advised [62].

7.2 Credential phishing needs no exploit

The chairman's account fell to one spoofed Google notice and a shortened link [46]. APT28 harvested webmail passwords on lookalike domains [49]. Phishing-resistant MFA would have made the harvested password insufficient; this is argued from the record, because the library has no D3FEND row for T1598.003 [57] (**Confirmed** as to the gap). For APT29's link phishing (T1566.002) the library maps URL Analysis, URL Reputation Analysis, Sender Reputation Analysis and Email Filtering [57]. Watching for lookalike registrations (actblues.com, accounts-qooqle.com) is the other cheap win [46].

7.3 Hunt for the second actor

Two services sat in the DNC with no collaboration identified [48] [49]. A Linux X-Agent survived remediation until about October 2016 [46]. An eviction should be followed by a hunt that assumes a second intruder and a missed implant.

7.4 Get logs off the host

The GRU cleared event logs on 13 May 2016, deleted its own panel logs on 20 June and ran CCleaner after reading a vendor's reporting [46]; both Bears cleared logs with `wevtutil` and reset timestamps [48]. Forwarding logs off-host as they are written makes those steps evidence rather than erasure.

7.5 Support staff, carriers and identity brokers are attack surface

The 2005 intruder reached a telephone provider's internal system and used accounts at an identity-data company [37]; by the book author's account he got provider credentials by phoning a store [38] (**Reported**). Publishers Weekly stresses the book's point about the blind spots phishing exploits [6] (**Reported**). Recovery and support flows need the same verification as the login, and identity-data accounts need the same vetting as the data.

7.6 Quiet destruction beats loud destruction

The Dark Avenger virus corrupted a sector every 16th run, so backups were already bad when anyone noticed [28]. Restores need testing against old, offline copies, not only the latest one. Executable allowlisting is the library's D3FEND countermeasure for T1204.002 [57].

7.7 Unsafe input, debug features and trust

`gets()` into a fixed stack buffer and a debug mode left on in shipping sendmail were the worm's two exploits [11] [12]. Trust files turned one compromised host into many [13], as the DCCC's credentials turned into the DNC's [46]. The 1988 fixes, `fgets` and sendmail 5.59 with debug off [10] [21], were small; finding them took a network of people who kept talking [11] [18].

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 (Enterprise), CAPEC, CWE and D3FEND. Only the DNC case has ATT&CK objects. For the other four cases every technique row is a retrospective mapping by this study of behaviour the primaries describe, graded **Inferred**. Every technique id was checked against the library's `data/attack/technique_profiles.jsonl` and `superseded_by.jsonl` and has a page under `/mitre/techniques/` [26] [52] [57]; the live ATT&CK pages for G0007, G0016, S0023, S0117 and T1584.005 were opened [53] [54] [55] [56] [75]. Revoked ids are shown under their v20.0 successors: T1672 Email Spoofing as T1684.002, T1070.001 Clear Windows Event Logs as T1685.005, and T1656 Impersonation as T1684.001 [52] [58]. ATT&CK for ICS does not apply.

Objects

Object	ATT&CK id	Library page	Relationship
Group	G0007 APT28	/mitre/groups/G0007.md	GRU Unit 26165; DCCC and DNC 2016 [46] [50] [53]
Group	G0016 APT29	/mitre/groups/G0016.md	SVR; DNC from summer 2015 per its description, no DNC procedure row [50] [54]
Software	S0023 CHOPSTICK (alias X-Agent)	/mitre/software/S0023.md	APT28 implant on DCCC and DNC hosts [46] [55]
Software	S0117 XTunnel	/mitre/software/S0117.md	APT28 tunnelling tool; description names the DNC [56]
Software	S0002 Mimikatz	/mitre/software/S0002.md	Used by both groups [47] [48]
Software	S0053 SeaDuke (SeaDaddy)	/mitre/software/S0053.md	APT29 implant in the DNC [48] [51]
Campaign	none	none	No campaign object covers the DNC intrusion; G0016's campaigns are C0023 Operation Ghost and C0024 SolarWinds Compromise, unrelated to the DNC [52] [54]
None	Morris worm, Dark Avenger viruses and MtE, the 2005 case, Mirai	none	No group, software or campaign object [26] [58] [75]; S0473 Avenger is unrelated to the Dark Avenger [58]
Not mapped	GRU Unit 74455	none	The opened record names the unit; this study binds no group id to it because no verified claim maps it. The unit's operations are in the Sandworm study

Case 1: Morris worm, Enterprise (all Inferred mappings)

ID	Name	Tactic	Event	Source
T1210	Exploitation of Remote Services	Lateral Movement	sendmail debug and fingerd overflow, 2 Nov 1988	[11] [12] [13]
T1059.004	Unix Shell	Execution	body piped to a shell; fingerd return to `/bin/sh`	[11] [12]
T1027.004	Compile After Delivery	Stealth	`l1.c` compiled on the target	[11]
T1105	Ingress Tool Transfer	Command and Control	grappling hook pulls object files	[11] [14]
T1021	Remote Services	Lateral Movement	`rsh` and `rexec`	[13]
T1078.003	Local Accounts	Initial Access	`rexec` with cracked local passwords	[13]
T1003.008	/etc/passwd and /etc/shadow	Credential Access	world-readable `/etc/passwd`	[13]
T1110.001	Password Guessing	Credential Access	null, name, GECOS guesses	[13]
T1110.002	Password Cracking	Credential Access	432-word list, then `/usr/dict/words`	[12] [13]
T1018	Remote System Discovery	Discovery	`hosts.equiv`, `.rhosts`, `.forward`	[13]
T1016	System Network Configuration Discovery	Discovery	netstat routing tables	[13]
T1046	Network Service Discovery	Discovery	probing random addresses	[13]
T1036.005	Match Legitimate Resource Name or Location	Stealth	runs as `sh`	[11]
T1036.011	Overwrite Process Arguments	Stealth	erased argument list	[11] [14]
T1070.004	File Deletion	Stealth	deleted its binary	[11] [14]
T1027	Obfuscated Files or Information	Stealth	strings XOR'd with 0x81; files encrypted in memory	[11] [14]
T1499	Endpoint Denial of Service	Impact	unintended load from reinfection (effect, not intent)	[7] [13]

Case 2: the Dark Avenger, Enterprise (all Inferred mappings)

ID	Name	Tactic	Event	Source
T1204.002	Malicious File	Execution	infected programs run by users, 1989	[28]
T1554	Compromise Host Software Binary	Persistence	parasitic infection of .COM and .EXE files	[28] [31]
T1091	Replication Through Removable Media	Initial Access	spread with copied, pirated software	[28]
T1080	Taint Shared Content	Lateral Movement	infected files uploaded to bulletin boards	[28] [30]
T1561.001	Disk Content Wipe	Impact	random sector overwritten every 16th run	[28]
T1565.001	Stored Data Manipulation	Impact	silent corruption of files and backups	[28]
T1485	Data Destruction	Impact	destructive payloads	[28]
T1036	Masquerading	Stealth	UScan posing as a scanner; trojanized VirusScan	[28] [30]
T1684.001	Impersonation	Stealth	uploads and viruses in Bontchev's name	[28]
T1027.014	Polymorphic Code	Stealth	Leech; MtE, 1992	[28] [33]
T1027.013	Encrypted/Encoded File	Stealth	MtE-wrapped virus bodies	[33]

T1561.002 Disk Structure Wipe was considered and left out as a weak fit.

Case 3: the phone case, Enterprise (Inferred mappings; rows from the book author are Reported)

ID	Name	Tactic	Event	Source
T1219	Remote Access Tools	Command and Control	program on an ISP employee's computer, Aug 2004	[37]
T1598.004	Spearphishing Voice	Reconnaissance	call to a store posing as corporate (**Reported**)	[38]
T1078	Valid Accounts	Initial Access	credentials handed over by the store (**Reported**)	[38]
T1589	Gather Victim Identity Information	Reconnaissance	identity-data company accounts, Jan 2005	[37]
T1585	Establish Accounts	Resource Development	accounts set up by an associate	[37]
T1136	Create Account	Persistence	free accounts created at the provider (weak fit)	[37]
T1530	Data from Cloud Storage	Collection	phone data held provider-side	[37]
T1498	Network Denial of Service	Impact	DoS ten minutes after a threat, Jun 2005	[37]

Case 4: the DNC, Enterprise

APT28 and GRU Unit 26165 (G0007):

ID	Name	Tactic	Event	Source	Grade
T1593	Search Open Websites/Domains	Reconnaissance	open-source research on the DNC, Mar 2016	[46]	Inferred mapping
T1590	Gather Victim Network Information	Reconnaissance	DNC and DCCC IP queries, 15 Mar and 7 Apr 2016	[46]	Inferred mapping
T1583.001	Domains	Resource Development	lookalike and phishing domains, dcleaks.com, actblues.com	[46] [48]	Confirmed
T1583.003	Virtual Private Server	Resource Development	bitcoin-funded VPS and leased servers	[46]	Inferred mapping
T1585.001	Social Media Accounts	Resource Development	"Alice Donovan", @dcleaks_, @Guccifer_2	[46]	Inferred mapping
T1585.002	Email Accounts	Resource Development	hi.mymail@yandex.com and hundreds of laundering accounts	[46]	Inferred mapping
T1598.003	Spearphishing Link	Reconnaissance	chairman's phish, 19 Mar 2016; fake webmail pages	[46] [49] [53]	Confirmed
T1684.002	Email Spoofing	Stealth	spoofed Google notices; mimicked staff address, 6 Apr 2016	[46] [52]	Inferred mapping
T1078	Valid Accounts	Initial Access	DCCC entry with phished credentials, 12 Apr 2016	[46] [49] [53]	Confirmed
T1199	Trusted Relationship	Initial Access	DCCC to DNC, 18 Apr 2016	[46] [53]	Confirmed
T1218.011	Rundll32	Stealth	X-Agent via `rundll32`	[48]	Confirmed
T1569.002	Service Execution	Execution	RemCOM deployment	[48]	Inferred mapping
T1056.001	Keylogging	Collection	X-Agent keylogging of DCCC staff	[46] [48]	Confirmed
T1113	Screen Capture	Collection	X-Agent screenshots	[46]	Inferred mapping
T1003.001	LSASS Memory	Credential Access	Mimikatz	[47] [53]	Confirmed
T1083	File and Directory Discovery	Discovery	keyword searches, 15 Apr 2016	[46] [53]	Confirmed
T1119	Automated Collection	Collection	DCCC and DNC networks	[53]	Confirmed
T1114.002	Remote Email Collection	Collection	DNC Exchange server, 25 May to 1 Jun 2016	[46]	Inferred mapping
T1560	Archive Collected Data	Collection	compression with a public tool; `rar.exe`	[46] [47] [53]	Confirmed
T1090	Proxy	Command and Control	middle server; X-Tunnel	[46] [48]	Confirmed
T1572	Protocol Tunneling	Command and Control	X-Tunnel over encrypted channels, 22 and 28 Apr 2016	[46] [48]	Inferred mapping
T1537	Transfer Data to Cloud Account	Exfiltration	cloud snapshots moved to GRU accounts, from 20 Sep 2016	[46] [47]	Inferred mapping
T1070.004	File Deletion	Stealth	CCleaner, 1 Jun 2016	[46] [53]	Confirmed

ID	Name	Tactic	Event	Source	Grade
T1685.005	Clear Windows Event Logs	Defense Impairment	`wevtutil` log clearing; 13 May 2016	[46] [48] [53]	Confirmed
T1070.006	Timestomp	Stealth	reset file timestamps	[48]	Confirmed

APT29 (G0016):

ID	Name	Tactic	Event	Source	Grade
T1566.002	Spearphishing Link	Initial Access	over 1,000 recipients, summer 2015	[49]	Confirmed
T1059.001	PowerShell	Execution	PowerShell backdoor	[48]	Confirmed
T1027.010	Command Obfuscation	Stealth	encoded PowerShell	[48]	Confirmed
T1546.003	Windows Management Instrumentation Event Subscription	Persistence	WMI persistence	[48]	Confirmed
T1003.001	LSASS Memory	Credential Access	PowerShell Mimikatz	[48]	Confirmed
T1071.001	Web Protocols	Command and Control	encrypted HTTP command and control	[48]	Inferred mapping

GRU Unit 74455, election infrastructure (no group id bound):

ID	Name	Tactic	Event	Source	Grade
T1595.002	Vulnerability Scanning	Reconnaissance	election sites researched for vulnerabilities, Jun to Jul 2016	[46]	Inferred mapping
T1190	Exploit Public-Facing Application	Initial Access	SQL injection at a state board of elections, Jun 2016	[46] [47]	Inferred mapping
T1566.001	Spearphishing Attachment	Initial Access	vendor-branded Word documents to Florida officials, Nov 2016	[46] [47]	Inferred mapping

Case 5: Mirai, Enterprise (all Inferred mappings)

ID	Name	Tactic	Event	Source
T1584.005	Botnet	Resource Development	hijacked IoT devices, from 1 Aug 2016	[59] [75]
T1046	Network Service Discovery	Discovery	SYN scans of 23 and 2323/TCP	[59]
T1078.001	Default Accounts	Initial Access	62 factory credentials	[59] [62]
T1110.001	Password Guessing	Credential Access	10 pairs per target	[59]
T1105	Ingress Tool Transfer	Command and Control	loader drops the bot	[59]
T1070.004	File Deletion	Stealth	deletes its binary	[59]
T1036	Masquerading	Stealth	random process name	[59]
T1489	Service Stop	Impact	kills TCP/22 and 23 services and rivals (closest fit)	[59]
T1190	Exploit Public-Facing Application	Initial Access	TCP/7547 CWMP variant, from 26 Nov 2016	[59] [62]
T1498.001	Direct Network Flood	Impact	Krebs, OVH and Dyn floods	[59] [61] [62]
T1499.002	Service Exhaustion Flood	Impact	HTTP flood, 25 Sep 2016	[59]
T1496.002	Bandwidth Hijacking	Impact	clickfraud botnet degrading consumers' bandwidth, Dec 2016 to Feb 2017	[69]

CAPEC, CWE and D3FEND

Case	CWE	CAPEC	D3FEND and mitigations (library mappings)	Grade
Morris	CWE-242 Use of Inherently Dangerous Function, CWE-121 Stack-based Buffer Overflow (fingerd); CWE-489 Active Debug Code, CWE-1188 Initialization of a Resource with an Insecure Default (sendmail); CWE-521 Weak Password Requirements. NVD lists CVE-1999-0095 as NVD-CWE-Other [16]	CAPEC-100 Overflow Buffers, CAPEC-16 Dictionary-based Password Attack, CAPEC-70 Try Common or Default Usernames and Passwords	T1210: Stack Frame Canary Validation, Segment Address Offset Randomization, Process Segment Execution Prevention, Memory Boundary Tracking, Application Protocol Command Analysis, Network Traffic Filtering; T1110.001 and T1110.002: Strong Password Policy, Credential Hardening, Multi-factor Authentication, Change Default Password; mitigations M1042 Disable or Remove Feature or Program, M1051 Update Software	CWE and CAPEC **Inferred** [27]; D3FEND **Confirmed** as library mappings [57]
Dark Avenger	none supported	none	T1204.002: Executable Allowlisting; T1561.001 has library D3FEND mappings on its technique page	**Confirmed** as library mappings [57] [58]
Phone case	none supported	CAPEC-407 Pretexting, CAPEC-412 Pretexting via Customer Service, CAPEC-415 Pretexting via Phone	T1078: Account Locking, Change Default Password	CAPEC **Inferred**, resting on the **Reported** call [38] [58]
DNC	none supported	none bound	T1566.002: URL Analysis, URL Reputation Analysis, Sender Reputation Analysis, Email Filtering; T1598.003 has no D3FEND row; T1078: Account Locking, Change Default Password	**Confirmed** as library mappings [57]
Mirai	CWE-1392 Use of Default Credentials (fits the record); CWE-798 Use of Hard-coded Credentials (fits only a hard-coded framing); the original Mirai exploited no software CVE [76]	CAPEC-70 (**Inferred**)	T1078.001: Change Default Password, Account Locking; T1498.001 and T1499.002: Inbound Session Volume Analysis, Inbound Traffic Filtering, Network Traffic Filtering	CWE **Confirmed** [76]; D3FEND **Confirmed** as library mappings [57]

Navigator layer

The study's layer is `navigator/library-layers/fancy-bear-goes-phishing.json`, listed in the library-layers index; open it in the ATT&CK Navigator. It is an Enterprise v20 layer of every technique in the five tables above, one entry per technique, with a comment naming the case and the source numbers. Score 100 marks a technique the opened record or ATT&CK states for the DNC actors; 50 marks a mapping that needs an interpretive step, which covers every row for the four cases ATT&CK does not cover. It is a curated case-study layer, not an official MITRE mapping.

Cross-cutting themes

Defaults, not genius. The book's thesis is that hacking is about people [1] [4]. The record adds that the people were let down by defaults: debug on, `gets()`, world-readable password files, factory passwords on cameras, a single password guarding a chairman's mailbox [11] [12] [13] [46] [59]. The Guardian's reviewer draws the book's conclusion that vulnerability could be cut if failing to take precautions were made an offence [3] (**Reported**).

The economics of the attacker. The reviewer also reads the book as treating hacking as a business of rational actors [3] (**Reported**). The record agrees in detail: underpaid Bulgarian programmers with no law against them [28], a teenager's free accounts and threats [37], a $95,000 bitcoin laundering operation [46], and Mirai's authors renting DDoS [74], extorting a company and running clickfraud while selling DDoS mitigation [65] [69] [73].

Responders as a community. In 1988 the defense was a mailing list and a phone tree, and the people who kept talking won [10] [11] [18]. In 1989 to 1992 the defense was a handful of researchers publishing analyses in *Virus Bulletin* while the Dark Avenger impersonated them [28] [30] [33]. In 2016 Mirai was measured by the USENIX Security 2017 study [59], and a journalist's own inquiry named its authors months before the pleas [63].

Numbers that travel. The 6,000-machine figure began as a guess on camera [10]. The library still pins the Dyn attack on Mirai's authors and gives a size that neither the USENIX paper nor US-CERT carries [59] [65]. Even the court record carries a likely date typo [65]. A case study is only as good as its willingness to say which number came from where.

The law catching up. The FBI calls Morris the first person convicted under the 1986 Act [15]. Bulgaria had no law to use [28]. The 2005 juvenile was handled in sealed proceedings with a sentence barring internet devices [37]. Mirai's authors drew probation for extraordinary cooperation [74] (**Reported**). Kirkus reads the book as arguing that patching after the fact eventually fails [5] (**Reported**).

Sources

#	Source	URL	Opened	Grade
1	*Fancy Bear Goes Phishing*, the book's own site (publisher and author copy)	https://www.fancybeargoesphishing.com/	3 Nov 2026	Reported
2	Yale Law School, Scott J. Shapiro faculty page (identifies the book)	https://law.yale.edu/scott-j-shapiro	3 Nov 2026	Confirmed
3	John Naughton, review, The Guardian, 22 May 2023	https://www.theguardian.com/books/2023/may/22/fancy-bear-goes-phishing-by-scott-shapiro-review-a-gripping-study-of-five-extraordinary-hacks	3 Nov 2026	Reported
4	Dorian Lynskey, review, The Guardian, 2 June 2023	https://www.theguardian.com/books/2023/jun/02/fancy-bear-goes-phishing-by-scott-j-shapiro-hacking-for-beginners	3 Nov 2026	Reported
5	Kirkus Reviews, *Fancy Bear Goes Phishing*, 20 Feb 2023	https://www.kirkusreviews.com/book-reviews/scott-j-shapiro/fancy-bear-goes-phishing/	3 Nov 2026	Reported
6	Publishers Weekly review, 31 Jan 2023	https://www.publishersweekly.com/978-0-374-60117-1	3 Nov 2026	Reported
7	*United States v. Morris*, 928 F.2d 504 (2d Cir. 1991), OpenJurist	https://openjurist.org/928/f2d/504/united-states-v-morris	3 Nov 2026	Confirmed
8	*United States v. Morris*, 928 F.2d 504, Justia	https://law.justia.com/cases/federal/appellate-courts/F2/928/504/452673/	3 Nov 2026	Confirmed
10	Eichin and Rochlis, MIT, chronology	https://web.mit.edu/eichin/www/virus/chronology.html	3 Nov 2026	Confirmed
11	Eichin and Rochlis, MIT, strategies	https://web.mit.edu/eichin/www/virus/strategies.html	3 Nov 2026	Confirmed
12	Donn Seeley, "A Tour of the Worm" (UNC course copy)	https://www.cs.unc.edu/~jeffay/courses/nidsS05/attacks/seely-RTMworm-89.html	3 Nov 2026	Confirmed
13	Eugene Spafford, "The Internet Worm Program: An Analysis", Purdue CSD-TR-823, record page	https://docs.lib.purdue.edu/cstech/702/	3 Nov 2026	Confirmed
14	Spafford, CSD-TR-823, full text	https://docs.lib.purdue.edu/cgi/viewcontent.cgi?article=1701&context=cstech	3 Nov 2026	Confirmed
15	FBI, "The Morris Worm: 30 Years Since First Major Attack on the Internet"	https://www.fbi.gov/news/stories/morris-worm-30-years-since-first-major-attack-on-internet-110218	3 Nov 2026	Confirmed
16	NVD, CVE-1999-0095	https://nvd.nist.gov/vuln/detail/CVE-1999-0095	3 Nov 2026	Confirmed
17	NVD API lookup used for the fingerd check	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-1999-0095	3 Nov 2026	Inferred
18	RFC 1135, "The Helminthiasis of the Internet"	https://www.rfc-editor.org/rfc/rfc1135.txt	3 Nov 2026	Confirmed
19	RFC 1087, "Ethics and the Internet"	https://www.rfc-editor.org/rfc/rfc1087.txt	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
20	SEI, CERT Division page	https://www.sei.cmu.edu/about/divisions/cert/	3 Nov 2026	Confirmed
21	SEI, 1988 CERT advisories	https://www.sei.cmu.edu/library/1988-cert-advisories/	3 Nov 2026	Confirmed
22	Cornell Chronicle (eCommons), on the Cornell Commission findings, 6 Apr 1989	https://ecommons.cornell.edu/handle/1813/25312	3 Nov 2026	Reported
23	Cornell Chronicle (eCommons), on the trial, 1990	https://ecommons.cornell.edu/handle/1813/25342	3 Nov 2026	Confirmed
24	GAO, IMTEC-89-57, product page	https://www.gao.gov/products/imtec-89-57	3 Nov 2026	Confirmed
25	Library, NOTABLE_INCIDENTS.md	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/NOTABLE_INCIDENTS.md	3 Nov 2026	Inferred
26	Library, mitre/techniques tree	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre/techniques	3 Nov 2026	Inferred
27	Library, mitre/capec tree and data/weaknesses/cwe.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre/capec	3 Nov 2026	Inferred
28	Vesselin Bontchev, "The Bulgarian and Soviet Virus Factories", 1991	https://bontchev.nlcv.bas.bg/papers/factory.html	3 Nov 2026	Confirmed
29	Sarah Gordon, interview with the Dark Avenger, 1992 (archive copy)	cryptohub.nl, path /zines/vxheavens/lib/asg02.html (plain text: an archive copy of the interview on a zine archive, kept as text)	3 Nov 2026	Confirmed
30	*Virus Bulletin*, December 1990	https://virusbulletin.com/uploads/pdf/magazine/1990/199012.pdf	3 Nov 2026	Confirmed
31	*Virus Bulletin*, February 1990	https://virusbulletin.com/uploads/pdf/magazine/1990/199002.pdf	3 Nov 2026	Confirmed
32	*Virus Bulletin*, April 1991	https://virusbulletin.com/uploads/pdf/magazine/1991/199104.pdf	3 Nov 2026	Confirmed
33	*Virus Bulletin*, April 1992	https://virusbulletin.com/uploads/pdf/magazine/1992/199204.pdf	3 Nov 2026	Confirmed
34	Vesselin Bontchev, "Future Trends in Virus Writing", 1994	https://bontchev.nlcv.bas.bg/papers/trends.html	3 Nov 2026	Confirmed
35	Christian Science Monitor, 19 May 1992	https://www.csmonitor.com/1992/0519/19081.html	3 Nov 2026	Reported
36	Wired, "Heart of Darkness", November 1997	https://www.wired.com/1997/11/heartof/	3 Nov 2026	Reported
37	US Department of Justice, D. Mass., release on the juvenile's sentence, 8 Sep 2005	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2005/juvenileSentboston.htm	3 Nov 2026	Confirmed
38	MSNBC, "Why Is This Happening?" transcript with Scott Shapiro	https://www.msnbc.com/msnbc-podcast/why-is-this-happening/decoding-information-age-scott-shapiro-podcast-transcript-n1306244	3 Nov 2026	Reported

#	Source	URL	Opened	Grade
39	Wired, "The Hacking of Hollywood", November 2015	https://www.wired.com/2015/11/the-hacking-of-hollywood/	3 Nov 2026	Reported
40	Ars Technica, 2 Jul 2014	https://arstechnica.com/information-technology/2014/07/feds-unmask-mystery-hacker-who-hamburgled-burger-king-twitter-account/	3 Nov 2026	Reported
41	CNBC, 23 Oct 2013	https://www.cnbc.com/2013/10/23/the-new-muggers-people-who-committed-shocking-cybercrimes.html	3 Nov 2026	Reported
42	SC Magazine, June 2014	https://www.scmagazine.com/news/cybercrime/fbi-charges-massachusetts-man-with-computer-hacking-payment-card-theft	3 Nov 2026	Reported
43	Boston Globe, 27 Oct 2014	https://www.bostonglobe.com/metro/2014/10/27/new-bedford-computer-hacker-sentenced-years-federal-prison/XwXxwL0TGGfiLk9QimRQiM/story.html	3 Nov 2026	Reported
44	TODAY, 4 Nov 2014	https://www.today.com/news/teen-hacker-tells-paris-hilton-hes-sorry-warns-parents-about-1d80266434	3 Nov 2026	Reported
45	UPI, 3 Jun 2014 (cited only for its conflict with the DOJ record)	https://www.upi.com/Top_News/US/2014/06/03/Paris-Hilton-hacker-faces-new-charges-after-breaking-into-community-colleges-network/9361401812305/	3 Nov 2026	Reported
46	*United States v. Netyksho et al.*, indictment, D.D.C. 1:18-cr-00215-ABJ, 13 Jul 2018 (National Security Archive copy)	https://nsarchive.gwu.edu/sites/default/files/documents/4599181/Indictment.pdf	3 Nov 2026	Confirmed
47	Special Counsel's report, Volume I	https://www.justice.gov/archives/sco/file/1373816/dl	3 Nov 2026	Confirmed
48	CrowdStrike, "Bears in the Midst: Intrusion into the Democratic National Committee", 14 Jun 2016 (also at crowdstrike.com/en-us/blog/bears-midst-intrusion-democratic-national-committee/)	https://www.crowdstrike.com/blog/bears-midst-intrusion-democratic-national-committee/	3 Nov 2026	Confirmed
49	DHS and FBI, JAR-16-20296A, GRIZZLY STEPPE, 29 Dec 2016	https://www.cisa.gov/sites/default/files/publications/JAR_16-20296A_GRIZZLY%20STEPPE-2016-1229.pdf	3 Nov 2026	Confirmed
50	Library, data/attack/groups.jsonl (v20.0)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/groups.jsonl	3 Nov 2026	Confirmed
51	Library, data/attack/software.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/software.jsonl	3 Nov 2026	Confirmed
52	Library, data/attack/superseded_by.jsonl	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/superseded_by.jsonl	3 Nov 2026	Confirmed
53	MITRE ATT&CK, G0007 APT28	https://attack.mitre.org/groups/G0007/	3 Nov 2026	Confirmed
54	MITRE ATT&CK, G0016 APT29	https://attack.mitre.org/groups/G0016/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
55	MITRE ATT&CK, S0023 CHOPSTICK	https://attack.mitre.org/software/S0023/	3 Nov 2026	Confirmed
56	MITRE ATT&CK, S0117 XTunnel	https://attack.mitre.org/software/S0117/	3 Nov 2026	Confirmed
57	Library, data/attack tree (technique_to_d3fend.jsonl and page checks)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	3 Nov 2026	Confirmed
58	Library repository (v20.0 data and retrospective mappings)	https://github.com/TeamStarWolf/TeamStarWolf	3 Nov 2026	Inferred
59	Antonakakis et al., "Understanding the Mirai Botnet", USENIX Security 2017	https://www.usenix.org/system/files/conference/usenixsecurity17/sec17-antonakakis.pdf	3 Nov 2026	Confirmed
61	Brian Krebs, "KrebsOnSecurity Hit With Record DDoS", Sep 2016	https://krebsonsecurity.com/2016/09/krebsonsecurity-hit-with-record-ddos/	3 Nov 2026	Confirmed
62	US-CERT TA16-288A, "Heightened DDoS Threat Posed by Mirai and Other Botnets", 14 Oct 2016	https://www.cisa.gov/news-events/alerts/2016/10/14/heightened-ddos-threat-posed-mirai-and-other-botnets	3 Nov 2026	Confirmed
63	Brian Krebs, "Who is Anna-Senpai, the Mirai Worm Author?", 18 Jan 2017	https://krebsonsecurity.com/2017/01/who-is-anna-senpai-the-mirai-worm-author/	3 Nov 2026	Confirmed
64	Brian Krebs, "Source Code for IoT Botnet 'Mirai' Released", Oct 2016	https://krebsonsecurity.com/2016/10/source-code-for-iot-botnet-mirai-released/	3 Nov 2026	Reported
65	Information, *United States v. Jha*, D. Alaska 3:17-cr-00164 (Mirai DDoS)	https://krebsonsecurity.com/wp-content/uploads/2017/12/Jha-DDoS.pdf	3 Nov 2026	Confirmed
66	Information, *United States v. White*, D. Alaska 3:17-cr-00165	https://krebsonsecurity.com/wp-content/uploads/2017/12/JWhite-DDoS.pdf	3 Nov 2026	Confirmed
67	Plea agreement, Jha, Mirai DDoS	https://krebsonsecurity.com/wp-content/uploads/2017/12/Jha-DDoS-Plea.pdf	3 Nov 2026	Confirmed
68	Plea agreement, White, Mirai DDoS (scanned)	https://krebsonsecurity.com/wp-content/uploads/2017/12/whiteddosplea.pdf	3 Nov 2026	Confirmed
69	Information, *United States v. Jha*, 3:17-cr-00163 (clickfraud)	https://krebsonsecurity.com/wp-content/uploads/2017/12/Jha1.pdf	3 Nov 2026	Confirmed
70	Plea agreement, Jha, clickfraud	https://krebsonsecurity.com/wp-content/uploads/2017/12/jhacf-plea.pdf	3 Nov 2026	Confirmed
71	Information, *United States v. Norman*, 3:17-cr-00166	https://krebsonsecurity.com/wp-content/uploads/2017/12/Norman-Clickfraud.pdf	3 Nov 2026	Confirmed
72	Plea agreement, Norman (scanned)	https://krebsonsecurity.com/wp-content/uploads/2017/12/NormanPlea.pdf	3 Nov 2026	Confirmed
73	Brian Krebs, "Mirai IoT Botnet Co-Authors Plead Guilty", Dec 2017	https://krebsonsecurity.com/2017/12/mirai-iot-botnet-co-authors-plead-guilty/	3 Nov 2026	Reported
74	Brian Krebs, "Mirai Botnet Authors Avoid Jail Time", Sep 2018	https://krebsonsecurity.com/2018/09/mirai-botnet-authors-avoid-jail-time/	3 Nov 2026	Reported
75	MITRE ATT&CK, T1584.005 Botnet	https://attack.mitre.org/techniques/T1584/005/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
76	MITRE CWE, CWE-1392 Use of Default Credentials	https://cwe.mitre.org/data/definitions/1392.html	3 Nov 2026	Confirmed

Not opened, and not cited as opened: the book's own text; the Cornell Commission report (cited through [22]); the full GAO PDF; the DOJ releases for the July 2018 indictment, the December 2017 pleas and the September 2018 sentencing; the judgments in the Alaska and New Jersey cases; OVH's founder's tweet.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Cybersecurity Book List (*Fancy Bear Goes Phishing*)
- Notable Incidents (the 1988, 2016 DNC and 2016 Mirai entries; corrections in Part 6)
- Threat Actors (APT28 and APT29; correction in Part 6)
- Malware Families (X-Agent, X-Tunnel, SeaDuke; Mirai has no ATT&CK object)
- CVE Reference (CVE-1999-0095; the original Mirai used no CVE)
- MITRE groups: G0007 APT28, G0016 APT29
- MITRE software: S0023 CHOPSTICK, S0117 XTunnel, S0002 Mimikatz, S0053 SeaDuke
- MITRE campaigns (APT29, not the DNC): C0023 Operation Ghost, C0024 SolarWinds Compromise (see the SolarWinds and SUNBURST study)
- MITRE techniques: T1598.003, T1566.002, T1078, T1078.001, T1199, T1056.001, T1685.005, T1210, T1110.001, T1110.002, T1584.005, T1498.001, T1027.014, and every row in the MITRE mappings Part
- CWE Reference, CAPEC Reference, D3FEND Reference
- Other case studies: Russia-Attributed Threat Actors (Units 26165 and 74455 and APT29 beyond 2016), Sandworm: The Operations in the Public Record (Unit 74455), SolarWinds and SUNBURST (APT29's C0024); and APT41: the public record, Stuxnet and Log4Shell, for later state and criminal operations that used the same credential, phishing and exploitation techniques
- Navigator layers
- All case studies